

Top 10 Web Hacking Techniques of 2017 - Voting Open



James Kettle
Director of Research
[@albinowax](#)



Published: Wednesday, 15 August 2018 at 13:50 UTC

Updated: Monday, 31 December 2018 at 09:30 UTC



The nominations are in for the [Top 10 Web Hacking Techniques of 2017](#), so it's time to start the community vote. We're inviting everyone to select their personal top 10, and the votes will be used to build a shortlist of 15 techniques for the final selection stage.

So, go ahead and browse through the candidates, [load up the voting form](#), and place your vote!

Update: the [results are now in!](#)

Here are the candidates (in no particular order):

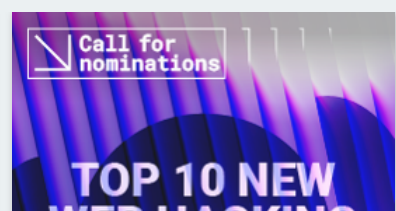
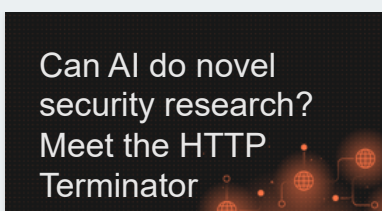
- [How I hacked hundreds of companies through their helpdesk](#)
- [Web Cache Deception Attack](#)
- [GitHubs post-CSP journey](#)

- [Request encoding to bypass web application firewalls](#)
- [Binary Webshell Through OPcache in PHP 7](#)
- [A deep dive into AWS S3 access controls taking full control over your assets](#)
- [CVE-2018-5175: Universal CSP strict-dynamic bypass in Firefox](#)
- [HaXmas: The True Meaning\(s\) of Metasploit](#)
- [The Good, The Bad and The Ugly of Safari in Client-Side Attacks](#)
- [Modern Alchemy: Turning XSS into RCE](#)
- [My Sweet Innocence Exposed - Eleven Reasons why we will all miss you, e](#)
- [Dont Trust The DOM: Bypassing XSS Mitigations Via Script Gadgets](#)
- [From Markdown to RCE in Atom](#)
- [The Absurdly Underestimated Dangers of CSV Injection](#)
- [Rare ASP.NET request validation bypass using request encoding](#)
- [Password Not Provided - Compromising Any Flurry Users Account](#)
- [\\$10k host header](#)
- [The .io Error - Taking Control of All .io Domains With a Targeted Registration](#)
- [Pivoting from blind SSRF to RCE with HashiCorp Consul](#)
- [Exploiting the unexploitable with lesser known browser tricks](#)
- [Why CSP Should be carefully crafted: Twitter XSS CSP Bypass](#)
- [Text/Plain Considered Harmful](#)
- [Autobinding vulns and Spring MVC](#)
- [Stealing Messenger.com Login Nonces](#)
- [Hacking Slack using postMessage and WebSocket-reconnect to steal your precious token](#)
- [Cloudflare Reverse Proxies are Dumping Uninitialized Memory](#)
- [The Attack of the Alerts and the Zombie Script \(IE\)](#)
- [Shopware 5.3.3: PHP Object Instantiation to Blind XXE](#)
- [Assorted WordPress DB prepare exploits](#)
- [A New Era of SSRF - Exploiting URL Parser in Trending Programming Languages!](#)
- [Cure53 Browser Security Whitepaper](#)
- [Friday The 13th JSON Attacks](#)
- [X41 Browser Security Whitepaper](#)
- [How I used google dorks to find 0-days](#)
- [MITM Attacks on HTTPS: Another Perspective](#)
- [Google Maps XSS \(by fiddling with Protobuf\)](#)
- [Advanced Flash Vulnerabilities](#)

Please proceed to [the voting form](#) to cast your vote.

← [Back to all articles](#)

Related Research





Burp Suite

[Web vulnerability scanner](#)
[Burp Suite Editions](#)
[Release Notes](#)

Vulnerabilities

[Cross-site scripting \(XSS\)](#)
[SQL injection](#)
[Cross-site request forgery](#)
[XML external entity injection](#)
[Directory traversal](#)
[Server-side request forgery](#)

Customers

[Organizations](#)
[Testers](#)
[Developers](#)

Company

[About](#)
[Careers](#)
[Contact](#)
[Legal](#)
[Privacy Notice](#)
[Modern Slavery Statement](#)

Insights

[Web Security Academy](#)
[Blog](#)
[Research](#)
[Engineering](#)



[Follow us](#)

© 2026 PortSwigger Ltd.

